

FarmGuard-AIoT: Threat Model & Security Architecture

Prepared By: Shem (Intelligence Routing & Capstone Lead)

This document outlines the security posture, threat vectors, and mitigation strategies for the FarmGuard-AIoT system. With the migration to an Edge AI architecture utilizing the ESP32-S3 Sense for local TinyML inference, the attack surface spans both physical edge hardware and the centralized low-code middleware stack (Node-RED, Mosquitto, InfluxDB, Grafana).

System Threat Matrix

The following matrix identifies the primary threats to the system, their potential impacts, and the specific engineering mitigations implemented to secure the deployment.

Threat	Target Component	Impact	Mitigation Strategy
Model Evasion / Data Poisoning	Edge AI (ESP32-S3)	Malicious inputs or extreme sensor drift bypass the TinyML classification boundaries, leading to missed alerts (false negatives) or constant false alarms.	Implement strict bounding logic and data normalization in the C++ firmware <i>before</i> passing values into the Edge Impulse/TensorFlow Lite model for inference.
Firmware Tampering & Physical Access	Edge Hardware (ESP32-S3)	An attacker physically accesses the node or flashes malicious firmware via serial, completely altering the edge logic and hijacking the device.	<i>Classroom Limitation:</i> Acknowledge physical vulnerability. <i>Production Mitigation:</i> Enable ESP32-S3 Secure Boot V2 and Flash Encryption to ensure

Threat	Target Component	Impact	Mitigation Strategy
			only signed firmware can execute.
Fake Device Injection (Spoofing)	Network / Mosquitto Broker	An unauthorized device connects to the MQTT broker and floods the topics with fake telemetry and false edge_state flags, ruining database integrity.	Enforce MQTT username and password authentication on the Mosquitto broker. Maintain a strict Access Control List (ACL) granting publish access only to the authenticated ESP32-S3 credentials.
Middleware Admin Takeover	Server / Node-RED & Grafana	An attacker guesses the URLs for the Node-RED editor or Grafana UI, modifies the routing logic, deletes historical time-series data, or disables alerts.	Disable all default logins. Enforce strong password policies for Node-RED and Grafana. Restrict editor access to trusted local IP addresses or VPN configurations where possible.
Data Interception (Eavesdropping)	Network Transport	Plaintext JSON telemetry and inference states are intercepted over the local WiFi network, exposing farm operational data.	<i>Classroom Limitation:</i> Acknowledge plaintext transport. <i>Production Mitigation:</i> Implement MQTTS (MQTT over TLS)

Threat	Target Component	Impact	Mitigation Strategy
			via port 8883 to encrypt the payload between the ESP32 and the broker.
Unauthorized Remote Actuation	Telegram Bot / Actuator	If bidirectional control is enabled via the Telegram Bot, an unauthorized user could issue a pump override command, causing over-irrigation or hardware damage.	Hardcode a strict identity whitelist in the Node-RED flow. The system must verify the incoming Telegram User ID against the approved admin list (Shem, Lee, Cecil) before routing the MQTT command back to the edge device.

Security Implementation Checklist

- **[] Broker Authentication:** Mosquitto requires a password file (mosquitto_passwd) and denies anonymous connections.
- **[] Database Least Privilege:** Node-RED uses an InfluxDB API token restricted to *Write-Only* permissions. Grafana uses a token restricted to *Read-Only* permissions.
- **[] UI Hardening:** Node-RED settings.js is configured with admin authentication enabled.
- **[] Alert Logic Security:** Node-RED flow explicitly checks the Telegram chat.id before executing any remote commands.
- **[] Edge Validation:** C++ firmware drops null or physically impossible sensor readings (e.g., negative humidity) before inference.